



GESTÃO DE USUÁRIOS E PERMISSÕES

BANCO DE DADOS NÃO RELACIONAIS

CST em Desenvolvimento de Software Multiplataforma



PROF. Me. TIAGO A. SILVA



CONTROLE DE USUÁRIOS E ROLES (PERMISSÕES)

- A gestão de usuários e permissões no MongoDB é fundamental para garantir a **segurança** dos dados, especialmente em ambientes de produção.
- A gestão é baseada em um modelo de controle de acesso baseado em funções (**RBAC** – Role-Based Access Control).



AUTENTICAÇÃO E AUTORIZAÇÃO

- **Autenticação:**

- Verifica a identidade de um usuário (login/senha, mecanismo externo etc).

- **Autorização:**

- Define o que o usuário pode ou não fazer, com base nas funções (roles) atribuídas.



A AUTENTICAÇÃO ESTÁ ATIVADA?

- Crie um usuário:

```
db.createUser({  
  user: "adminUser",  
  pwd: "Fatec@2025",  
  roles: [ { role: "userAdminAnyDatabase",  
    db: "admin" }, "readWriteAnyDatabase" ]  
})
```
- Altere o **mongod.conf** para:

```
security:  
  authorization: enabled
```
- Reinicie o servidor do mongo.



EXEMPLO DE ROLES (PERMISSÕES)

ROLES	DESCRIÇÃO
read	Leitura de dados de um banco
readWrite	Leitura e escrita em um banco
dbAdmin	Administração do banco (índices, validações)
userAdmin	Gerencia usuários em um banco
clusterAdmin	Gerencia cluster (shards, replicação)
readAnyDatabase	Leitura em qualquer banco (requer acesso ao admin)
dbOwner	Controle total sobre um banco

VERIFICANDO AS ROLES DE UM USUÁRIO

- Ver usuário:
 - `db.getUsers()`
- Ver todas as roles de um usuário:
 - `db.getUser("nomeUsuario")`
- Ver todas roles disponíveis:
 - `db.getRoles({ showBuiltinRoles: true })`



DICAS ÚTEIS E BOAS PRÁTICAS

- ✓ Use o princípio do menor privilégio.
- ✓ Separe usuários por perfil: leitura, escrita, admin.
- ✓ Nunca use root para aplicações.
- ✓ Em produção, sempre ative a autenticação e o uso de TLS/SSL.

ROLES

Permissões

ROLES DE BANCO DE DADOS

FUNÇÃO	DESCRIÇÃO
read	Permite somente leitura (find) nas coleções do banco.
readWrite	Leitura e escrita em todas as coleções do banco.
readWriteAnyDatabase	Leitura e escrita em qualquer banco (somente em admin).
dbAdmin	Permissões administrativas no banco (índices, stats, validação), sem acesso a dados .
dbAdminAnyDatabase	Mesmo que dbAdmin, mas em qualquer banco (somente em admin).
userAdmin	Pode criar, deletar e gerenciar usuários no banco.
userAdminAnyDatabase	Gerencia usuários em qualquer banco (somente em admin).
dbOwner	Permissões completas sobre um banco (inclui readWrite , dbAdmin e userAdmin).

ROLES DE CLUSTERS

FUNÇÃO	DESCRIÇÃO
clusterAdmin	Acesso total à administração do cluster.
clusterManager	Gerencia a configuração de cluster (replicação, shards, etc), mas sem acesso a usuários .
clusterMonitor	Pode monitorar o status do cluster (usado por ferramentas de monitoramento).
hostManager	Gerencia instâncias do MongoDB (restart, logs, etc).
backup	Permite realizar backups (dump).
restore	Permite restaurar dados (restore).

ROLES DE REPLICAÇÃO

FUNÇÃO	DESCRIÇÃO
__system	Função interna usada pelo MongoDB para processos do sistema. Não deve ser atribuída manualmente.
restore	Usada para restaurar dados de backups.
readWriteAnyDatabase	Útil para scripts ou aplicações administrativas.
root	Acesso total a tudo (superusuário).
restore	Permite operações de restauração de dados (mongorestore).

ROLES PERSONALIZADAS

Criar, listar, modificar e remover

ROLES PERSONALIZADAS

- Criar roles específicas com **permissões granulares**, por exemplo, permitir apenas leitura da coleção clientes:

```
db.createRole({  
  role: "leitorClientes",  
  privileges: [  
    {  
      resource: { db: "vendas", collection: "clientes" },  
      actions: [ "find" ]  
    }  
  ],  
  roles: []  
})
```

COMO EXIBIR ROLES PERSONALIZADAS?

- Exibe todas as roles internas e personalizadas:
 - `db.getRoles({ showBuiltinRoles: true })`
- Exibe apenas as roles personalizadas:
 - `db.getRoles({ showBuiltinRoles: false })`
- Ver detalhes de uma role:
 - `db.getRole("leitorApenasClientes", { showPrivileges: true })`
- Remover uma role personalizada
 - `db.dropRole("leitorApenasClientes")`

ATRIBUIR ROLES A USUÁRIOS

- Atribuindo Role ao Usuário
 - `db.grantRolesToUser("joao", [ { role: "leitorApenasClientes", db: "meuBanco" } ])`
- Removendo Role de Usuário:
 - `db.revokeRolesFromUser("joao", [ { role: "leitorApenasClientes", db: "meuBanco" } ])`

ATRIBUINDO E REMOVENDO PRIVILÉGIOS DE UMA ROLE

- Concedendo privilégio à uma role:
 - `db.grantPrivilegesToRole("leitorApenasClientes", [ { resource: { db: "meuBanco", collection: "clientes" }, actions: [ "count" ] } ])`
- Revogando privilégio de uma role:
 - `db.revokePrivilegesFromRole("leitorApenasClientes", [ { resource: { db: "meuBanco", collection: "clientes" }, actions: [ "find" ] } ])`

MANIPULAÇÃO DE USUÁRIOS

Criar, modificar e remover

CRIAÇÃO DE USUÁRIOS

```
db.createUser({  
  user: "joao",  
  pwd: "senha123",  
  roles: [ { role: "readWrite",  
            db: "meuBanco" } ]  
})
```



CONSULTAR DADOS DE UM USUÁRIO

- Dados de um usuário específico:
 - `db.getUser("joao")`
- Consultar todos os usuários:
 - `db.getUsers()`



MODIFICAÇÃO DE USUÁRIOS

```
db.updateUser("joao", {  
  pwd: "novaSenha456",  
  roles: [ { role: "read", db: "meuBanco" } ]  
})
```

- Modifica apenas a senha:
 - `db.changeUserPassword("joao", "outraSenha789")`

REMOÇÃO DE USUÁRIO

- Remove um usuário específico:
 - `db.dropUser("joao")`
- Remover todos os usuários:
 - `db.dropAllUsers()`



EXERCÍCIOS

EXERCÍCIOS COM ROLES E USUÁRIOS

- 1) Crie um usuário chamado **cidadao** no banco **Detran** com senha **1234** que tenha apenas permissão de leitura neste banco.
- 2) Crie um usuário chamado **agente** no banco **Detran** com senha **abc123** e permissões de leitura e escrita.
- 3) Crie um usuário chamado **adminGoverno** no banco **Detran**, com senha **admin321**, com permissão para gerenciar usuários neste banco.
- 4) Liste todos os usuários criados no banco **Detran**. Depois, use outro comando para obter as informações completas de um usuário específico.

EXERCÍCIOS COM ROLES E USUÁRIOS

- 5) Altere a senha do usuário **cidadao** para **novaSenha456**.
- 6) Crie uma role chamada **visualizadorProdutos** no banco **PetShop** que permita apenas o comando **find** na coleção **produtos**.
- 7) Conceda a role **visualizadorProdutos** ao usuário **balconista** do banco de dados **PetShop**.

EXERCÍCIOS COM ROLES E USUÁRIOS

- 8) Altere a role **visualizadorProdutos** para também permitir o uso do comando **count** na coleção **produtos**.
- 9) Revogue a role **visualizadorProdutos** do usuário **balconista**. Depois, exclua essa role do banco loja.
- 10) Crie um usuário chamado **rootUser** no banco **PetShop** com senha **super123**, com a role **root**.

OBRIGADO!

- Encontre este **material on-line** em:
 - Slides: Plataforma Microsoft Teams
- Em caso de **dúvidas**, entre em contato:
 - **Prof. Tiago:** tiago.silva238@fatec.sp.gov.br

